



АКАДЕМИЯ
КОДЕБАЙ

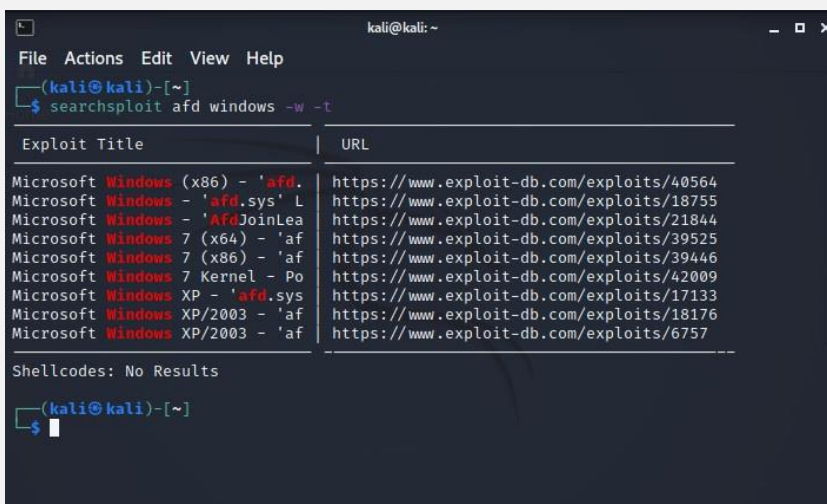
ПРОФЕССИЯ ПЕНТЕСТЕР

Друзья, всех приветствую! Давайте рассмотрим еще один пример! Предположим, мы находимся в середине теста на проникновение и имеем непривилегированный доступ к машине Windows. Продолжая собирать информацию, мы понимаем, что она может быть уязвима к эксплойту, о котором мы читали и который начинается с букв a, f и d, но мы не можем вспомнить полное название эксплойта. Для этого нам нужно зайти на сайт <https://www.exploit-db.com>, в строке поиска ввести "afd windows" и загрузить эксплойты соответствующие критериям поиска. Мы можем сделать это вручную через веб-сайт, что не займет много времени, но, если мы потратим время на написание Bash-сценария, мы сможем легко использовать его для поиска и последующей автоматической загрузки эксплойтов.

Используя то, что мы теперь знаем о сценариях, давайте попробуем автоматизировать эту задачу.

Мы начнем с утилиты SearchSploit в Kali Linux. SearchSploit – это инструмент поиска в командной строке для Exploit-DB, который позволяет нам взять автономную копию базы данных Exploit с собой, куда бы мы не пошли. Мы передадим "afd windows" в качестве строки поиска, будем использовать -w для возврата URL <https://www.exploit-db.com>, а не локальный путь, и -t для поиска по названию эксплойта:

```
kali@kali:~$ searchsploit afd windows -w -t
```



Exploit Title	URL
Microsoft Windows (x86) - 'afd.sys' L	https://www.exploit-db.com/exploits/40564
Microsoft Windows - 'afd.sys' L	https://www.exploit-db.com/exploits/18755
Microsoft Windows - 'AfdJoinLea	https://www.exploit-db.com/exploits/21844
Microsoft Windows 7 (x64) - 'af	https://www.exploit-db.com/exploits/39525
Microsoft Windows 7 (x86) - 'af	https://www.exploit-db.com/exploits/39446
Microsoft Windows 7 Kernel - Po	https://www.exploit-db.com/exploits/42009
Microsoft Windows XP - 'afd.sys	https://www.exploit-db.com/exploits/17133
Microsoft Windows XP/2003 - 'af	https://www.exploit-db.com/exploits/18176
Microsoft Windows XP/2003 - 'af	https://www.exploit-db.com/exploits/6757

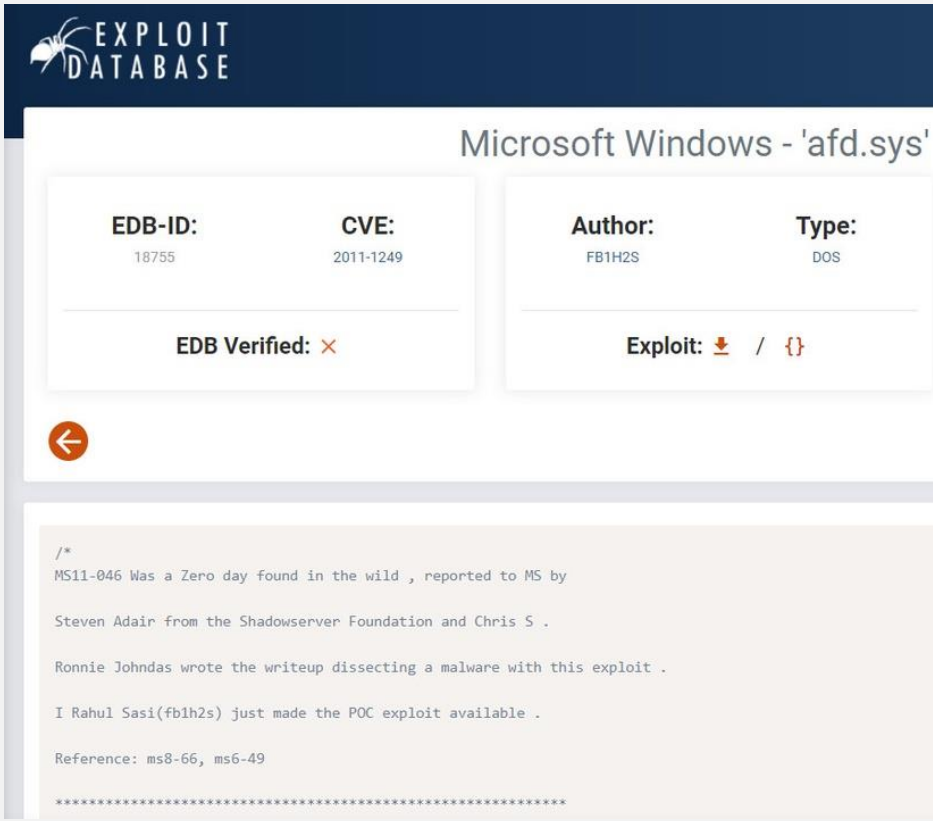
Shellcodes: No Results

Это хорошее начало, но нам нужно обработать результаты. На данный момент нас интересует только URL эксплойта. Поэтому давайте в grep введем в поиск "http", а затем вырежем то, что нам нужно. Мы будем использовать разделитель полей "|" и извлечем второе поле:

```
kali@kali:~$ searchsploit afd windows -w -t | grep http | cut -f 2 -d "|"
```

```
(kali@kali)-[~]
└─$ searchsploit afd windows -w -t | grep http | cut -f 2 -d "|"
https://www.exploit-db.com/exploits/40564
https://www.exploit-db.com/exploits/18755
https://www.exploit-db.com/exploits/21844
https://www.exploit-db.com/exploits/39525
https://www.exploit-db.com/exploits/39446
https://www.exploit-db.com/exploits/42009
https://www.exploit-db.com/exploits/17133
https://www.exploit-db.com/exploits/18176
https://www.exploit-db.com/exploits/6757
```

Это выглядит намного лучше. Теперь, когда у нас есть URL для каждого эксплойта, мы можем использовать цикл Bash для загрузки файлов и сохранения их локально. Однако, прежде чем мы это сделаем, мы заметим, что на каждой странице есть ссылка для загрузки "чистого" кода эксплойта, что, собственно, нам и нужно:



The screenshot shows the Exploit Database interface for the entry 'Microsoft Windows - 'afd.sys''. It displays the EDB-ID (18755), CVE (2011-1249), Author (FB1H2S), and Type (DOS). Below this, it indicates 'EDB Verified: ✗' and 'Exploit: ⬇ / {}'. A back arrow icon is visible. The main content area contains a comment block starting with '/* MS11-046 Was a Zero day found in the wild , reported to MS by Steven Adair from the Shadowserver Foundation and Chris S . Ronnie Johndas wrote the writeup dissecting a malware with this exploit . I Rahul Sasi(fb1h2s) just made the POC exploit available . Reference: ms8-66, ms6-49 *****'.

Мы видим, что на каждой оригинальной странице (например, /exploits/40564) есть ссылка на сам код эксплойта (например, /raw/40564). Вооружившись этой информацией, мы запускаем sed (sed 's/exploits/raw/'), чтобы изменить URL загрузки и вставляем его в однострочную команду Bash для загрузки кода эксплойтов:



```
kali@kali:~$ for e in $(searchsploit afd windows -w -t | grep http | cut -f 2 -d "|");  
do exp_name=$(echo $e | cut -d "/" -f 5) && url=$(echo $e | sed 's/exploits/raw/')  
&& wget -q --no-check-certificate $url -O $exp_name; done
```

Обратите внимание на использование цикла `for`, который перебирает URL-адреса, которые мы получили с помощью SearchSploit. Внутри цикла мы устанавливаем в `exp_name` имя эксплойта (например, 40564), в `url` место загрузки. Если все прошло успешно (&&), мы берем эксплойт с помощью `wget` (без проверки сертификата), сохраняя его локально.

Давайте проверим что эксплойты действительно были загружены с помощью команды `file`:

```
kali@kali:~$ ls -l
```

```
kali@kali:~$ file 40564
```

```
(kali@kali)~[~]  
$ ls -l  
total 152  
-rw-r--r-- 1 kali kali 1363 Jan 29 10:26 17133  
-rw-r--r-- 1 kali kali 12215 Jan 29 10:26 18176  
-rw-r--r-- 1 kali kali 9698 Jan 29 10:26 18755  
-rw-r--r-- 1 kali kali 11590 Jan 29 10:26 21844  
-rw-r--r-- 1 kali kali 10575 Jan 29 10:26 39446  
-rw-r--r-- 1 kali kali 14193 Jan 29 10:26 39525  
-rw-r--r-- 1 kali kali 32674 Jan 29 10:26 40564  
-rw-r--r-- 1 kali kali 12636 Jan 29 10:26 42009  
-rw-r--r-- 1 kali kali 612 Jan 29 10:26 6757  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Desktop  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Documents  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Downloads  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Music  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Pictures  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Public  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Templates  
drwxr-xr-x 2 kali kali 4096 Sep 8 05:48 Videos  
  
(kali@kali)~[~]  
$ file 40564  
40564: C source, ASCII text, with CRLF line terminators
```

Мы можем проверить каждый эксплойт и убедиться, что мы действительно скачали код эксплойтов:

```
kali@kali:~$ cat 40564
```

```
(kali@kali)-[~]  
$ cat 40564  
/*  
#####  
# Exploit Title: Windows x86 (all versions) AFD privilege escalation ( MS11-046)  
# Date: 2016-10-16  
# Exploit Author: Tomislav Paskalev  
# Vulnerable Software:  
#   Windows XP SP3 x86  
#   Windows XP Pro SP2 x64  
#   Windows Server 2003 SP2 x86  
#   Windows Server 2003 SP2 x64  
#   Windows Server 2003 SP2 Itanium-based Systems  
#   Windows Vista SP1 x86  
#   Windows Vista SP2 x86  
#   Windows Vista SP1 x64  
#   Windows Vista SP2 x64  
#   Windows Server 2008 x86  
#   Windows Server 2008 SP2 x86  
#   Windows Server 2008 x64  
#   Windows Server 2008 SP2 x64  
#   Windows Server 2008 Itanium-based Systems  
#   Windows Server 2008 SP2 Itanium-based Systems  
#   Windows 7 x86  
#   Windows 7 SP1 x86  
#   Windows 7 x64  
#   Windows 7 SP1 x64  
#   Windows Server 2008 R2 x64  
#   Windows Server 2008 R2 SP1 x64  
#   Windows Server 2008 R2 Itanium-based Systems
```

Несмотря на то, что мы добились успеха с помощью однострочника Bash, его не особо легко использовать повторно. Давайте соберем всё вместе в сценарии Bash, чтобы решить эту проблему:

```
kali@kali:~$ cat > ./ssploits.sh  
#!/bin/bash  
for e in $(searchsploit afd windows -w -t | grep http | cut -f 2 -d "|")  
do  
exp_name=$(echo $e | cut -d "/" -f 5)  
url=$(echo $e | sed 's/exploits/raw/')  
wget -q --no-check-certificate $url -O $exp_name  
done  
kali@kali:~$ chmod +x ./ssploits.sh  
kali@kali:~$ ./ssploits.sh
```

Теперь мы можем изучить интересующие нас эксплойты и протестировать их (это мы будем делать в следующих уроках в соответствующей части курса) на тестовой машине.